



ARKA HEALTH, INC.

ACCESS CONTROL & IDENTITY MANAGEMENT POLICY

*Workforce security, information access management, and authentication — 45 C.F.R. §§ 164.308(a)
(3)–(4), 164.312(a), 164.312(d)*

ARKA-SEC-003 · Version 1.0 · Confidential — Internal

Document No.	ARKA-SEC-003
Version	1.0
Effective Date	June 10, 2026
Last Reviewed	June 10, 2026
Document Owner	Arri Kanna, Founder & Chief Executive Officer — Privacy & Security Officer
Approved By	Arri Kanna, Founder & Chief Executive Officer
Classification	Confidential — Internal
Review Cycle	Annual, and upon any material change in operations, systems, or law

This document contains confidential and proprietary information of ARKA Health, Inc. (“ARKA”). It is furnished for informational and compliance purposes, may not be reproduced or disclosed to any third party without the prior written consent of ARKA, and must be returned or destroyed upon request. Nothing in this document constitutes legal advice.

1. PURPOSE AND SCOPE

This Policy governs the authorization, establishment, modification, review, and termination of all human and machine access to ARKA Health, Inc. information systems, and the technical mechanisms by which identity is asserted and verified. It applies to every account — Workforce Member, contractor, service, and administrative — across production infrastructure, source control, corporate SaaS, and any system containing ePHI.

2. ACCOUNT LIFECYCLE

1. **Authorization.** Access is granted only upon the documented approval of the Security Officer, by reference to a role in the access matrix. Each role enumerates the systems, environments, and data scopes it confers; no access is granted by default or by inheritance.
2. **Provisioning.** Accounts are unique to an individual; shared and generic interactive accounts are prohibited. Each account is attributable to a named person or a registered service identity (45 C.F.R. § 164.312(a)(2)(i)).
3. **Modification.** Role changes require re-approval; privileges not used for ninety (90) days are removed upon quarterly review.
4. **Termination.** Upon separation or role change of any Workforce Member, all access shall be revoked or adjusted within twenty-four (24) hours, and in the case of involuntary separation, prior to or contemporaneously with notification. A termination checklist (credentials, tokens, devices, repository and SaaS membership) shall be completed and retained (45 C.F.R. § 164.308(a)(3)(ii) (C)).
5. **Review.** The Security Officer shall conduct and document a quarterly access review of all production, source-control, and ePHI-relevant accounts, reconciling each account against the current workforce roster and the access matrix; discrepancies are treated as incidents under ARKA-SEC-006.

3. AUTHENTICATION STANDARDS

1. **Multi-factor authentication** is mandatory for all access to production infrastructure, cloud consoles, source control, corporate identity, email, and any system containing ePHI. Phishing-resistant factors (FIDO2/WebAuthn hardware keys or platform passkeys) are required for administrative access; SMS one-time codes are prohibited as a second factor for administrative accounts.
2. **Passwords**, where used, shall be a minimum of fourteen (14) characters, screened against known-compromised-credential lists, stored only as salted adaptive hashes, and never transmitted or stored in plaintext; mandatory periodic rotation is not required absent indication of compromise, consistent with NIST SP 800-63B.
3. **Session controls.** Application sessions enforce inactivity timeouts not exceeding fifteen (15) minutes for clinical-context interfaces and twenty-four (24) hours for administrative consoles, with automatic logoff (45 C.F.R. § 164.312(a)(2)(iii)); workstation screen locks engage at ten (10) minutes (ARKA-SEC-012).

4. **Secrets and keys.** Service credentials, API keys, and tokens are issued per-service with least privilege, stored in a managed secrets store (never in source code), rotated at least every twelve (12) months and immediately upon personnel separation or suspected exposure, and scanned for in CI to prevent repository leakage.
5. **Emergency access.** A sealed break-glass procedure provides emergency access to ePHI-bearing systems where normal authentication is unavailable (45 C.F.R. § 164.312(a)(2)(ii)); each use generates an alert, requires dual notification to the Security Officer and CEO, and is reviewed within twenty-four (24) hours.

4. PRIVILEGED ACCESS

Administrative privileges are confined to the minimum set of individuals required to operate the Company (at present, the founding engineering staff), are exercised through dedicated administrative roles rather than day-to-day accounts where the platform supports separation, and are logged in full under ARKA-SEC-005. Production database access for engineering support requires a ticketed justification and, where the underlying platform supports it, time-boxed credentials that expire within twenty-four (24) hours.

5. CUSTOMER-FACING ACCESS CONTROLS

The ARKA Platform enforces tenant isolation at the data layer (row-level security keyed to tenant identifiers), role-based authorization within each tenant (clinician, administrative staff, reviewer, auditor), and authentication delegated to enterprise identity providers via SMART on FHIR / OAuth 2.0 and OpenID Connect for EHR-launched contexts. Customer administrative users manage their own workforce assignments; ARKA personnel access customer tenants only through the support-access workflow described in Section 4 and only as permitted by the applicable BAA.

DOCUMENT CONTROL & REVISION HISTORY

Version	Date	Author / Reviewer	Description of Change
0.9	May 22, 2026	A. Kanna (drafting); external review pending	Initial draft circulated for internal review and counsel comment.
1.0	June 10, 2026	A. Kanna, Privacy & Security Officer	Adopted as effective policy of ARKA Health, Inc. by written approval of the undersigned officer.

ADOPTION AND APPROVAL

The undersigned, being the duly designated Privacy Officer and Security Officer of ARKA Health, Inc., hereby adopts this document as an official policy of the Company, effective as of the Effective Date set forth on the cover page hereof. This document shall be reviewed no less frequently than annually and upon any material change to the Company's operations, information systems, or applicable law, and may be amended only in accordance with ARKA-GOV-001 (Information Security & Compliance Program Charter).

ARKA HEALTH, INC.



By: _____

Name: Arri Kanna

Title: Founder & Chief Executive Officer; Privacy & Security Officer

Date: June 10, 2026